

PRACTICAL CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

CLS Critical Security Controls v8.1

Practical Implementation, Measurement, Evidence, and Open-Source Tools

A working manual for managers, junior analysts, students, career changers, assessors, and security teams

Alberto (Al) Leiva

First Edition • July 2026

Inside: 18 Controls • 153 Safeguards • IG1, IG2, IG3 • measurement • evidence • tools • manager playbook • labs • career preparation

Publication and Use Notice

Author: Alberto (Al) Leiva

Edition: First Edition, July 2026

This independent educational manual is not a Center for Internet Security publication, certification, accreditation, audit report, legal opinion, or guarantee of security or compliance. CIS Controls and CIS Benchmarks are trademarks of the Center for Internet Security. Use official CIS resources for exact content and current guidance.

The CIS Controls are cybersecurity best practices. They do not replace applicable laws, regulations, contracts, sector requirements, risk assessment, or management responsibility. A mapping shows relationships; it does not automatically prove compliance with another framework.

Ethical and authorized use

Use technical tools only on assets, networks, applications, cloud accounts, repositories, and data that you own or are specifically authorized in writing to assess. Use synthetic information and isolated systems in laboratories.

Preface

A practical introduction to prioritized cyber defense and evidence-based measurement.

The CIS Controls turn common defensive needs into focused Safeguards. Their strength is practical prioritization: know what you own, control software and data, secure configurations and identities, manage vulnerabilities and logs, prepare for disruption and attacks, and test whether defenses work.

Version 8.1 is the current edition. It is an iterative update to v8 that realigned mappings to NIST CSF 2.0, expanded reserved-term definitions, revised asset classes and Safeguard mappings, corrected minor issues, clarified some Safeguards, and incorporated the Govern security function in mappings. The 18 Controls and 153 Safeguards remain the central structure.

A tool installation is not implementation. Effective implementation requires defined scope, complete populations, secure configuration, operating evidence, trained owners, exception handling, measurement, correction, and retesting. Managers decide priorities and resources; analysts make those decisions reliable through accurate inventories and evidence.

How to Use This Manual

- Managers should begin with Chapters 1–5 and 24–25.
- Junior analysts should study the 18 Control chapters, measurement method, tools, lab, and interview chapter.
- Technical teams should connect every Safeguard to assets, data, owners, procedures, configuration, monitoring, exception handling, and evidence.
- Assessors should use the official CIS Controls Assessment Specification for exact inputs, operations, measures, metrics, assumptions, and procedure reviews.

True Word contents: This document contains a native Word table-of-contents field. The chapter guide will contain verified page numbers for this edition. After editing, right-click the contents and choose Update Field, then Update entire table.

Table of Contents

Publication and Use Notice	2
Ethical and authorized use	2
Preface	3
How to Use This Manual	4
Table of Contents	4
1. CIS Controls v8.1 Foundations	7
2. Implementation Groups and Prioritization.....	8
3. Governance, Scope, and Ownership.....	9
4. Measurement with the CIS Assessment Specification	10
5. Implementation Roadmap	11
6. Control 1 — Inventory and Control of Enterprise Assets	12
7. Control 2 — Inventory and Control of Software Assets	13
8. Control 3 — Data Protection.....	14
9. Control 4 — Secure Configuration of Enterprise Assets and Software	16
10. Control 5 — Account Management	18
11. Control 6 — Access Control Management.....	19
12. Control 7 — Continuous Vulnerability Management	21
13. Control 8 — Audit Log Management.....	23
14. Control 9 — Email and Web Browser Protections	24
15. Control 10 — Malware Defenses.....	25

16. Control 11 — Data Recovery	26
17. Control 12 — Network Infrastructure Management.....	27
18. Control 13 — Network Monitoring and Defense	28
19. Control 14 — Security Awareness and Skills Training	30
20. Control 15 — Service Provider Management.....	31
21. Control 16 — Application Software Security	32
22. Control 17 — Incident Response Management.....	34
23. Control 18 — Penetration Testing	36
24. Open-Source Tools	37
24.1 CIS Controls Navigator	37
24.2 CIS Controls Assessment Specification.....	37
24.3 CIS-CAT Lite	37
24.4 CISO Assistant	38
24.5 Wazuh	38
24.6 osquery.....	38
24.7 OpenSCAP	38
24.8 Lynis	38
24.9 Nmap	39
24.10 Greenbone Community Edition	39
24.11 Trivy	39
24.12 OWASP ZAP	39
24.13 Suricata	39
24.14 Keycloak	39
24.15 DefectDojo.....	40
24.16 Velociraptor	40
25. Manager’s CIS Controls Playbook.....	41
26. Junior Analyst Career Guide	42
26.1 Typical junior work.....	42
27. Fictional Laboratory and Portfolio	44
28. Thirty-Day Learning Plan.....	45
29. Interview Preparation	46
29.1 What are the CIS Controls?	46
29.2 What is IG1?.....	46
29.3 Does IG1 fit every requirement?	46

29.4 How do you measure a Safeguard?	46
29.5 Why are inventories important?.....	46
29.6 Vulnerability scan versus penetration test?	46
29.7 Does a framework mapping prove compliance?.....	46
29.8 What can a junior analyst conclude?	46
29.9 Questions to ask the employer.....	46
30. Templates, Glossary, Index, and References	48
30.1 Safeguard measurement workpaper	48
30.2 Finding and retest record	48
30.3 Glossary	48
30.4 Subject index	49
30.5 Official references.....	49

1. CIS Controls v8.1 Foundations

The current version, structure, purpose, and limitations.



The 18 Controls organize 153 prioritized, measurable Safeguards

Figure 1. The 18 CIS Critical Security Controls

- CIS Controls v8.1 was published in June 2024 and remains the current edition as of July 2026.
- The Controls are prioritized best practices designed to defend systems and networks against prevalent attacks.
- The framework contains 18 Controls and 153 Safeguards.
- Safeguards map to asset classes, security functions, and Implementation Groups.
- Version 8.1 aligns its NIST CSF mapping to CSF 2.0 and includes Govern mappings.
- Official mappings exist for multiple frameworks, but implementation must be verified separately for each applicable requirement.

Layer	Purpose
Control	Broad defensive outcome, such as asset inventory or incident response
Safeguard	Focused action that can be assigned, implemented, and measured
Asset class	Type of subject affected, such as devices, software, data, network, users, or documentation
Security function	Govern, Identify, Protect, Detect, Respond, or Recover mapping
Implementation Group	Recommended prioritization based on risk profile and resources
Assessment measure	Inputs, operations, measures, metrics, and procedure review used to evaluate a Safeguard

2. Implementation Groups and Prioritization

How IG1, IG2, and IG3 help organizations choose a realistic starting point.



Implementation Groups build on one another: IG3 contains all 153 Safeguards

Figure 2. Implementation Group progression

Group	Safeguards	Typical situation	Objective
IG1	56	Limited security resources and expertise; lower sensitivity; high need for basic continuity	Essential cyber hygiene against common attacks
IG2	IG1 + 74	Multiple departments, greater complexity, sensitive information, and more operational dependence	Manage increased risk and operational complexity
IG3	IG1 + IG2 + 23 = 153	Security specialists, sensitive or regulated data, critical services, and sophisticated threats	Reduce targeted and advanced attack impact

- Every enterprise should start with IG1 according to CIS guidance.
- Select an IG by considering data sensitivity, critical services, threat exposure, legal and contractual duties, business tolerance, technology, staffing, and expertise.
- An IG is a prioritization aid, not permission to ignore a material risk or mandatory requirement.
- Document tailored additions, sequencing, exceptions, risk acceptance, owners, and dates.
- Use the official CIS Controls Navigator to filter v8.1 Safeguards and review mappings.

3. Governance, Scope, and Ownership

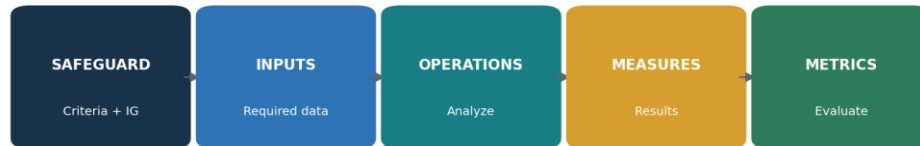
The management foundation needed to make Safeguards operate consistently.

- Define business objectives, critical services, sensitive data, legal and contractual obligations, threat profile, risk tolerance, and chosen Implementation Group.
- Create complete inventories for enterprise assets, software, data, accounts, authentication systems, network infrastructure, logs, suppliers, applications, and recovery resources.
- Assign one accountable owner for each Safeguard and operational owners for each affected platform or process.
- Define scope, applicability, dependencies, service-provider responsibilities, allowed exceptions, approval authority, and review triggers.
- Plan funding, people, skills, technology, time, and change management.
- Define metrics and reporting before implementation so coverage and failure are visible.
- Operate a governance cycle: prioritize, implement, measure, correct, retest, and improve.

Role	Decision or responsibility
Executive sponsor	Direction, risk tolerance, funding, escalation, and accountability
Control owner	Safeguard design, scope, procedure, measurement, exceptions, and improvement
Asset or service owner	Accurate inventory, approved use, configuration, business impact, and remediation
Security operations	Monitoring, alerting, investigation, response, and evidence
IT / Engineering	Implementation, change control, patching, configuration, and recovery
GRC / Analyst	Mapping, evidence, measurement, findings, action tracking, and reporting
Internal audit / assessor	Objective criteria, testing, limitations, and conclusions
Service provider	Contracted controls, evidence, incidents, changes, and exit support

4. Measurement with the CIS Assessment Specification

A repeatable method for deciding whether Safeguards are implemented.



The CIS Assessment Specification explains what to measure, while the enterprise controls how it measures

Figure 3. CIS Safeguard measurement structure

Element	Question
Safeguard metadata	What is the exact Safeguard, asset class, security function, and IG?
Dependencies	What other Safeguards or populations must exist first?
Assumptions	What accepted condition affects the measurement?
Inputs	What complete and reliable data is required?
Operations	What analysis must be performed on the inputs?
Measures	What counts, lists, dates, configurations, or outcomes result?
Metrics	How are measures calculated and interpreted?
Procedure review	Does a documented process exist and include required elements?

- Define the exact Safeguard and scoped population.
- Obtain required inputs and validate completeness, accuracy, timing, ownership, and source reliability.
- Follow the official measurement operations or document an equivalent reliable method.
- Retain measure calculations and the underlying exception population—not only a percentage.
- Evaluate whether the Safeguard is implemented and how well it is operating.
- Assign a correction for missing coverage, bad configuration, overdue review, exceptions, or unreliable data.
- Retest using the same criteria and refreshed population.
- Report scope, result, exception, limitation, owner, action, and date.

5. Implementation Roadmap

A practical sequence from inventories to tested resilience.

1. Choose and document the initial Implementation Group and any required additions.
2. Build and reconcile the core populations: assets, software, data, accounts, authentication systems, network, suppliers, applications, and logs.
3. Implement IG1 safeguards with owners, procedures, coverage metrics, exceptions, and evidence.
4. Secure identities, configurations, vulnerabilities, email, browsers, malware defenses, backups, and essential monitoring.
5. Exercise incident response and recovery before a real emergency.
6. Measure every applicable Safeguard using reliable inputs and repeatable operations.
7. Correct incomplete coverage and repeat failures; verify fixes through retesting.
8. Expand toward IG2 or IG3 based on risk, obligations, maturity, and threat exposure.
9. Use official mappings to coordinate other frameworks without treating mappings as automatic compliance.

Implementation principle: A smaller group of Safeguards that is fully scoped, operated, measured, and improved is more defensible than a long list marked complete without reliable evidence.

6. Control 1 — Inventory and Control of Enterprise Assets

All 5 Safeguards, plain meaning, verification focus, and example evidence.



Asset and software inventories are living populations that drive every downstream control

Figure 4. Asset and software inventory cycle

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for inventory and control of enterprise assets.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
1.1	Establish and Maintain Detailed Enterprise Asset Inventory	Put a repeatable, owned process or technical control in place to establish and Maintain Detailed Enterprise Asset Inventory, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	asset inventory, owners, approval status, active/passive discovery, DHCP/IPAM logs, unauthorized-asset tickets
1.2	Address Unauthorized Assets	Put a repeatable, owned process or technical control in place to address Unauthorized Assets, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	asset inventory, owners, approval status, active/passive discovery, DHCP/IPAM logs, unauthorized-asset tickets
1.3	Utilize an Active Discovery Tool	Put a repeatable, owned process or technical control in place to utilize an Active Discovery Tool, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	asset inventory, owners, approval status, active/passive discovery, DHCP/IPAM logs, unauthorized-asset tickets
1.4	Use DHCP Logging to Update Enterprise Asset Inventory	Put a repeatable, owned process or technical control in place to use DHCP Logging to Update Enterprise Asset Inventory, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	asset inventory, owners, approval status, active/passive discovery, DHCP/IPAM logs, unauthorized-asset tickets
1.5	Use a Passive Asset Discovery Tool	Put a repeatable, owned process or technical control in place to use a Passive Asset Discovery Tool, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	asset inventory, owners, approval status, active/passive discovery, DHCP/IPAM logs, unauthorized-asset tickets

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

7. Control 2 — Inventory and Control of Software Assets

All 7 Safeguards, plain meaning, verification focus, and example evidence.

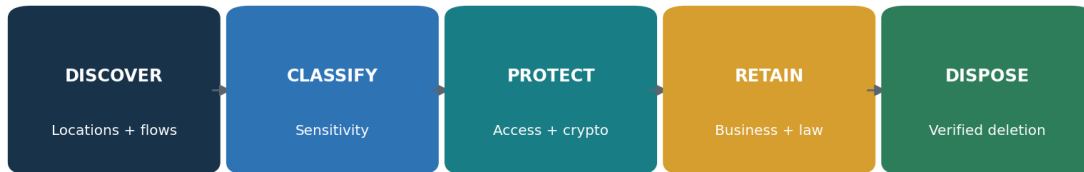
Control purpose: Strengthen the enterprise by implementing and measuring safeguards for inventory and control of software assets.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
2.1	Establish and Maintain a Software Inventory	Put a repeatable, owned process or technical control in place to establish and Maintain a Software Inventory, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	software inventory, support status, approved list, discovery results, exceptions, allowlisting policy and events
2.2	Ensure Authorized Software is Currently Supported	Put a repeatable, owned process or technical control in place to ensure Authorized Software is Currently Supported, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	software inventory, support status, approved list, discovery results, exceptions, allowlisting policy and events
2.3	Address Unauthorized Software	Put a repeatable, owned process or technical control in place to address Unauthorized Software, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	software inventory, support status, approved list, discovery results, exceptions, allowlisting policy and events
2.4	Utilize Automated Software Inventory Tools	Put a repeatable, owned process or technical control in place to utilize Automated Software Inventory Tools, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	software inventory, support status, approved list, discovery results, exceptions, allowlisting policy and events
2.5	Allowlist Authorized Software	Put a repeatable, owned process or technical control in place to allowlist Authorized Software, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	software inventory, support status, approved list, discovery results, exceptions, allowlisting policy and events
2.6	Allowlist Authorized Libraries	Put a repeatable, owned process or technical control in place to allowlist Authorized Libraries, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	software inventory, support status, approved list, discovery results, exceptions, allowlisting policy and events
2.7	Allowlist Authorized Scripts	Put a repeatable, owned process or technical control in place to allowlist Authorized Scripts, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	software inventory, support status, approved list, discovery results, exceptions, allowlisting policy and events

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

8. Control 3 — Data Protection

All 14 Safeguards, plain meaning, verification focus, and example evidence.



Data protection follows information throughout its complete life cycle

Figure 5. Data protection life cycle

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for data protection.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
3.1	Establish and Maintain a Data Management Process	Put a repeatable, owned process or technical control in place to establish and Maintain a Data Management Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.2	Establish and Maintain a Data Inventory	Put a repeatable, owned process or technical control in place to establish and Maintain a Data Inventory, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.3	Configure Data Access Control Lists	Put a repeatable, owned process or technical control in place to configure Data Access Control Lists, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.4	Enforce Data Retention	Put a repeatable, owned process or technical control in place to enforce Data Retention, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.5	Securely Dispose of Data	Put a repeatable, owned process or technical control in place to securely Dispose of Data, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.6	Encrypt Data on End-User Devices	Put a repeatable, owned process or technical control in place to encrypt Data on End-User Devices, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.7	Establish and Maintain a Data Classification Scheme	Put a repeatable, owned process or technical control in place to establish and Maintain a Data Classification Scheme, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.8	Document Data Flows	Put a repeatable, owned process or technical control in place to document Data Flows, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs

ID	Safeguard	Plain meaning	Verification focus	Example evidence
3.9	Encrypt Data on Removable Media	Put a repeatable, owned process or technical control in place to encrypt Data on Removable Media, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.10	Encrypt Sensitive Data in Transit	Put a repeatable, owned process or technical control in place to encrypt Sensitive Data in Transit, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.11	Encrypt Sensitive Data At Rest	Put a repeatable, owned process or technical control in place to encrypt Sensitive Data At Rest, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.12	Segment Data Processing and Storage Based on Sensitivity	Put a repeatable, owned process or technical control in place to segment Data Processing and Storage Based on Sensitivity, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.13	Deploy a Data Loss Prevention Solution	Put a repeatable, owned process or technical control in place to deploy a Data Loss Prevention Solution, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs
3.14	Log Sensitive Data Access	Put a repeatable, owned process or technical control in place to log Sensitive Data Access, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	data inventory, classification, flows, ACLs, retention, disposal, encryption, DLP and access logs

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

9. Control 4 — Secure Configuration of Enterprise Assets and Software

All 12 Safeguards, plain meaning, verification focus, and example evidence.

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for secure configuration of enterprise assets and software.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
4.1	Establish and Maintain a Secure Configuration Process	Put a repeatable, owned process or technical control in place to establish and Maintain a Secure Configuration Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.2	Establish and Maintain a Secure Configuration Process for Network Infrastructure	Put a repeatable, owned process or technical control in place to establish and Maintain a Secure Configuration Process for Network Infrastructure, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, frequency, coverage, exceptions, session locks, admin protocols, defaults, services and mobile settings
4.3	Configure Automatic Session Locking on Enterprise Assets	Put a repeatable, owned process or technical control in place to configure Automatic Session Locking on Enterprise Assets, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.4	Implement and Manage a Firewall on Servers	Put a repeatable, owned process or technical control in place to implement and Manage a Firewall on Servers, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.5	Implement and Manage a Firewall on End-User Devices	Put a repeatable, owned process or technical control in place to implement and Manage a Firewall on End-User Devices, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.6	Securely Manage Enterprise Assets and Software	Put a repeatable, owned process or technical control in place to securely Manage Enterprise Assets and Software, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.7	Manage Default Accounts on Enterprise Assets and Software	Put a repeatable, owned process or technical control in place to manage Default Accounts on Enterprise Assets and Software, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.8	Uninstall or Disable Unnecessary Services on Enterprise Assets and Software	Put a repeatable, owned process or technical control in place to uninstall or Disable Unnecessary Services on Enterprise Assets and Software, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.9	Configure Trusted DNS Servers on Enterprise Assets	Put a repeatable, owned process or technical control in place to configure Trusted DNS Servers on Enterprise Assets, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.10	Enforce Automatic Device Lockout on Portable End-User Devices	Put a repeatable, owned process or technical control in place to enforce Automatic Device Lockout on Portable End-User Devices, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.11	Enforce Remote Wipe Capability on Portable End-User Devices	Put a repeatable, owned process or technical control in place to enforce Remote Wipe Capability on Portable End-User Devices, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings
4.12	Separate Enterprise Workspaces on Mobile End-User Devices	Put a repeatable, owned process or technical control in place to separate Enterprise Workspaces on Mobile End-User Devices, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	configuration standards, benchmark results, firewalls, session locks, admin protocols, defaults, services and mobile settings

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

10. Control 5 — Account Management

All 6 Safeguards, plain meaning, verification focus, and example evidence.

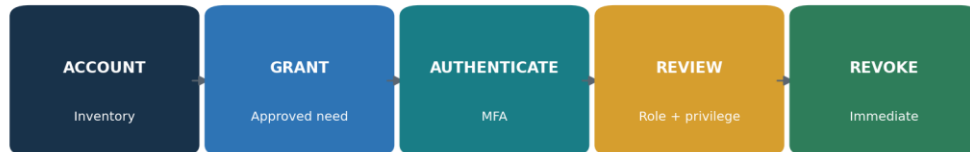
Control purpose: Strengthen the enterprise by implementing and measuring safeguards for account management.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
5.1	Establish and Maintain an Inventory of Accounts	Put a repeatable, owned process or technical control in place to establish and Maintain an Inventory of Accounts, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	account populations, owners, dates, password policy, dormant-account actions, admin and service-account inventories
5.2	Use Unique Passwords	Put a repeatable, owned process or technical control in place to use Unique Passwords, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	account populations, owners, dates, password policy, dormant-account actions, admin and service-account inventories
5.3	Disable Dormant Accounts	Put a repeatable, owned process or technical control in place to disable Dormant Accounts, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	account populations, owners, dates, password policy, dormant-account actions, admin and service-account inventories
5.4	Restrict Administrator Privileges to Dedicated Administrator Accounts	Put a repeatable, owned process or technical control in place to restrict Administrator Privileges to Dedicated Administrator Accounts, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	account populations, owners, dates, password policy, dormant-account actions, admin and service-account inventories
5.5	Establish and Maintain an Inventory of Service Accounts	Put a repeatable, owned process or technical control in place to establish and Maintain an Inventory of Service Accounts, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	account populations, owners, dates, password policy, dormant-account actions, admin and service-account inventories
5.6	Centralize Account Management	Put a repeatable, owned process or technical control in place to centralize Account Management, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	account populations, owners, dates, password policy, dormant-account actions, admin and service-account inventories

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

11. Control 6 — Access Control Management

All 8 Safeguards, plain meaning, verification focus, and example evidence.



Account management identifies identities; access management governs what those identities may do

Figure 6. Identity and access life cycle

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for access control management.

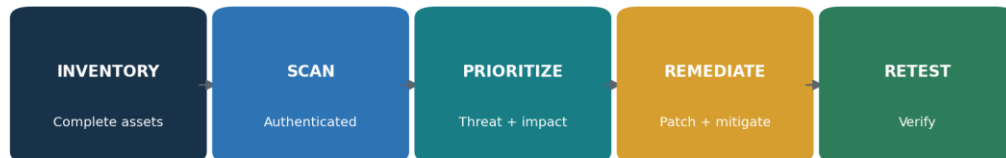
ID	Safeguard	Plain meaning	Verification focus	Example evidence
6.1	Establish an Access Granting Process	Put a repeatable, owned process or technical control in place to establish an Access Granting Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	grant/revoke tickets, MFA coverage, authentication-system inventory, roles, entitlements and access reviews
6.2	Establish an Access Revoking Process	Put a repeatable, owned process or technical control in place to establish an Access Revoking Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	grant/revoke tickets, MFA coverage, authentication-system inventory, roles, entitlements and access reviews
6.3	Require MFA for Externally-Exposed Applications	Put a repeatable, owned process or technical control in place to require MFA for Externally-Exposed Applications, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	grant/revoke tickets, MFA coverage, authentication-system inventory, roles, entitlements and access reviews
6.4	Require MFA for Remote Network Access	Put a repeatable, owned process or technical control in place to require MFA for Remote Network Access, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	grant/revoke tickets, MFA coverage, authentication-system inventory, roles, entitlements and access reviews
6.5	Require MFA for Administrative Access	Put a repeatable, owned process or technical control in place to require MFA for Administrative Access, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	grant/revoke tickets, MFA coverage, authentication-system inventory, roles, entitlements and access reviews
6.6	Establish and Maintain an Inventory of Authentication and Authorization Systems	Put a repeatable, owned process or technical control in place to establish and Maintain an Inventory of Authentication and Authorization Systems, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	grant/revoke tickets, MFA coverage, authentication-system inventory, roles, entitlements and access reviews
6.7	Centralize Access Control	Put a repeatable, owned process or technical control in place to centralize Access Control, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	grant/revoke tickets, MFA coverage, authentication-system inventory, roles, entitlements and access reviews

ID	Safeguard	Plain meaning	Verification focus	Example evidence
6.8	Define and Maintain Role-Based Access Control	Put a repeatable, owned process or technical control in place to define and Maintain Role-Based Access Control, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	grant/revoke tickets, MFA coverage, authentication-system inventory, roles, entitlements and access reviews

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

12. Control 7 — Continuous Vulnerability Management

All 7 Safeguards, plain meaning, verification focus, and example evidence.



Vulnerability management is continuous and ends with verified correction—not with a scan report

Figure 7. Continuous vulnerability management

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for continuous vulnerability management.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
7.1	Establish and Maintain a Vulnerability Management Process	Put a repeatable, owned process or technical control in place to establish and Maintain a Vulnerability Management Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	processes, feeds, asset coverage, authenticated scans, patch results, exceptions, remediation tickets and rescans
7.2	Establish and Maintain a Remediation Process	Put a repeatable, owned process or technical control in place to establish and Maintain a Remediation Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	processes, feeds, asset coverage, authenticated scans, patch results, exceptions, remediation tickets and rescans
7.3	Perform Automated Operating System Patch Management	Put a repeatable, owned process or technical control in place to perform Automated Operating System Patch Management, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	processes, feeds, asset coverage, authenticated scans, patch results, exceptions, remediation tickets and rescans
7.4	Perform Automated Application Patch Management	Put a repeatable, owned process or technical control in place to perform Automated Application Patch Management, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	processes, feeds, asset coverage, authenticated scans, patch results, exceptions, remediation tickets and rescans
7.5	Perform Automated Vulnerability Scans of Internal Enterprise Assets	Put a repeatable, owned process or technical control in place to perform Automated Vulnerability Scans of Internal Enterprise Assets, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	processes, feeds, asset coverage, authenticated scans, patch results, exceptions, remediation tickets and rescans
7.6	Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets	Put a repeatable, owned process or technical control in place to perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	processes, feeds, asset coverage, authenticated scans, patch results, exceptions, remediation tickets and rescans
7.7	Remediate Detected Vulnerabilities	Put a repeatable, owned process or technical control in place to remediate Detected Vulnerabilities, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	processes, feeds, asset coverage, authenticated scans, patch results, exceptions, remediation tickets and rescans

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

13. Control 8 — Audit Log Management

All 12 Safeguards, plain meaning, verification focus, and example evidence.

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for audit log management.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
8.1	Establish and Maintain an Audit Log Management Process	Put a repeatable, owned process or technical control in place to establish and Maintain an Audit Log Management Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.2	Collect Audit Logs	Put a repeatable, owned process or technical control in place to collect Audit Logs, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.3	Ensure Adequate Audit Log Storage	Put a repeatable, owned process or technical control in place to ensure Adequate Audit Log Storage, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.4	Standardize Time Synchronization	Put a repeatable, owned process or technical control in place to standardize Time Synchronization, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.5	Collect Detailed Audit Logs	Put a repeatable, owned process or technical control in place to collect Detailed Audit Logs, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.6	Collect DNS Query Audit Logs	Put a repeatable, owned process or technical control in place to collect DNS Query Audit Logs, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.7	Collect URL Request Audit Logs	Put a repeatable, owned process or technical control in place to collect URL Request Audit Logs, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.8	Collect Command-Line Audit Logs	Put a repeatable, owned process or technical control in place to collect Command-Line Audit Logs, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.9	Centralize Audit Logs	Put a repeatable, owned process or technical control in place to centralize Audit Logs, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.10	Retain Audit Logs	Put a repeatable, owned process or technical control in place to retain Audit Logs, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.11	Conduct Audit Log Reviews	Put a repeatable, owned process or technical control in place to conduct Audit Log Reviews, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention
8.12	Collect Service Provider Logs	Put a repeatable, owned process or technical control in place to collect Service Provider Logs, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	logging requirements, source inventory, storage, time settings, detailed logs, central platform, reviews and retention

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

14. Control 9 — Email and Web Browser Protections

All 7 Safeguards, plain meaning, verification focus, and example evidence.

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for email and web browser protections.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
9.1	Ensure Use of Only Fully Supported Browsers and Email Clients	Put a repeatable, owned process or technical control in place to ensure Use of Only Fully Supported Browsers and Email Clients, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	browser and email inventories, support status, DNS/URL filtering, extension policy, DMARC and attachment controls
9.2	Use DNS Filtering Services	Put a repeatable, owned process or technical control in place to use DNS Filtering Services, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	browser and email inventories, support status, DNS/URL filtering, extension policy, DMARC and attachment controls
9.3	Maintain and Enforce Network-Based URL Filters	Put a repeatable, owned process or technical control in place to maintain and Enforce Network-Based URL Filters, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	browser and email inventories, support status, DNS/URL filtering, extension policy, DMARC and attachment controls
9.4	Restrict Unnecessary or Unauthorized Browser and Email Client Extensions	Put a repeatable, owned process or technical control in place to restrict Unnecessary or Unauthorized Browser and Email Client Extensions, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	browser and email inventories, support status, DNS/URL filtering, extension policy, DMARC and attachment controls
9.5	Implement DMARC	Put a repeatable, owned process or technical control in place to implement DMARC, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	browser and email inventories, support status, DNS/URL filtering, extension policy, DMARC and attachment controls
9.6	Block Unnecessary File Types	Put a repeatable, owned process or technical control in place to block Unnecessary File Types, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	browser and email inventories, support status, DNS/URL filtering, extension policy, DMARC and attachment controls
9.7	Deploy and Maintain Email Server Anti-Malware Protections	Put a repeatable, owned process or technical control in place to deploy and Maintain Email Server Anti-Malware Protections, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	browser and email inventories, support status, DNS/URL filtering, extension policy, DMARC and attachment controls

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

15. Control 10 — Malware Defenses

All 7 Safeguards, plain meaning, verification focus, and example evidence.

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for malware defenses.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
10.1	Deploy and Maintain Anti-Malware Software	Put a repeatable, owned process or technical control in place to deploy and Maintain Anti-Malware Software, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	endpoint coverage, anti-malware configuration, updates, removable-media controls, behavior alerts and response tickets
10.2	Configure Automatic Anti-Malware Signature Updates	Put a repeatable, owned process or technical control in place to configure Automatic Anti-Malware Signature Updates, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	endpoint coverage, anti-malware configuration, updates, removable-media controls, behavior alerts and response tickets
10.3	Disable Autorun and Autoplay for Removable Media	Put a repeatable, owned process or technical control in place to disable Autorun and Autoplay for Removable Media, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	endpoint coverage, anti-malware configuration, updates, removable-media controls, behavior alerts and response tickets
10.4	Configure Automatic Anti-Malware Scanning of Removable Media	Put a repeatable, owned process or technical control in place to configure Automatic Anti-Malware Scanning of Removable Media, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	endpoint coverage, anti-malware configuration, updates, removable-media controls, behavior alerts and response tickets
10.5	Enable Anti-Exploitation Features	Put a repeatable, owned process or technical control in place to enable Anti-Exploitation Features, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	endpoint coverage, anti-malware configuration, updates, removable-media controls, behavior alerts and response tickets
10.6	Centrally Manage Anti-Malware Software	Put a repeatable, owned process or technical control in place to centrally Manage Anti-Malware Software, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	endpoint coverage, anti-malware configuration, updates, removable-media controls, behavior alerts and response tickets
10.7	Use Behavior-Based Anti-Malware Software	Put a repeatable, owned process or technical control in place to use Behavior-Based Anti-Malware Software, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	endpoint coverage, anti-malware configuration, updates, removable-media controls, behavior alerts and response tickets

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

16. Control 11 — Data Recovery

All 5 Safeguards, plain meaning, verification focus, and example evidence.

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for data recovery.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
11.1	Establish and Maintain a Data Recovery Process	Put a repeatable, owned process or technical control in place to establish and Maintain a Data Recovery Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	recovery plan, backup coverage, protected and isolated copies, restore tests, results, gaps and retests
11.2	Perform Automated Backups	Put a repeatable, owned process or technical control in place to perform Automated Backups, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	recovery plan, backup coverage, protected and isolated copies, restore tests, results, gaps and retests
11.3	Protect Recovery Data	Put a repeatable, owned process or technical control in place to protect Recovery Data, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	recovery plan, backup coverage, protected and isolated copies, restore tests, results, gaps and retests
11.4	Establish and Maintain an Isolated Instance of Recovery Data	Put a repeatable, owned process or technical control in place to establish and Maintain an Isolated Instance of Recovery Data, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	recovery plan, backup coverage, protected and isolated copies, restore tests, results, gaps and retests
11.5	Test Data Recovery	Put a repeatable, owned process or technical control in place to test Data Recovery, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	recovery plan, backup coverage, protected and isolated copies, restore tests, results, gaps and retests

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

17. Control 12 — Network Infrastructure Management

All 8 Safeguards, plain meaning, verification focus, and example evidence.

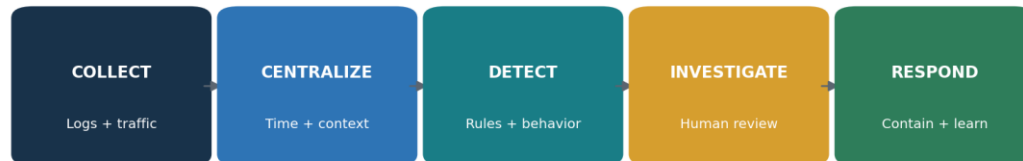
Control purpose: Strengthen the enterprise by implementing and measuring safeguards for network infrastructure management.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
12.1	Ensure Network Infrastructure is Up-to-Date	Put a repeatable, owned process or technical control in place to ensure Network Infrastructure is Up-to-Date, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	network inventory, versions, architecture, diagrams, admin paths, AAA, secure protocols, VPN and admin workstations
12.2	Establish and Maintain a Secure Network Architecture	Put a repeatable, owned process or technical control in place to establish and Maintain a Secure Network Architecture, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	network inventory, versions, architecture, diagrams, admin paths, AAA, secure protocols, VPN and admin workstations
12.3	Securely Manage Network Infrastructure	Put a repeatable, owned process or technical control in place to securely Manage Network Infrastructure, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	network inventory, versions, architecture, diagrams, admin paths, AAA, secure protocols, VPN and admin workstations
12.4	Establish and Maintain Architecture Diagrams	Put a repeatable, owned process or technical control in place to establish and Maintain Architecture Diagrams, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	network inventory, versions, architecture, diagrams, admin paths, AAA, secure protocols, VPN and admin workstations
12.5	Centralize Network Authentication, Authorization, and Auditing	Put a repeatable, owned process or technical control in place to centralize Network Authentication, Authorization, and Auditing, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	network inventory, versions, architecture, diagrams, admin paths, AAA, secure protocols, VPN and admin workstations
12.6	Use Secure Network Management and Communication Protocols	Put a repeatable, owned process or technical control in place to use Secure Network Management and Communication Protocols, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	network inventory, versions, architecture, diagrams, admin paths, AAA, secure protocols, VPN and admin workstations
12.7	Ensure Remote Devices Use a VPN and Enterprise AAA	Put a repeatable, owned process or technical control in place to ensure Remote Devices Use a VPN and Enterprise AAA, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	network inventory, versions, architecture, diagrams, admin paths, AAA, secure protocols, VPN and admin workstations
12.8	Maintain Dedicated Computing Resources for Administrative Work	Put a repeatable, owned process or technical control in place to maintain Dedicated Computing Resources for Administrative Work, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	network inventory, versions, architecture, diagrams, admin paths, AAA, secure protocols, VPN and admin workstations

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

18. Control 13 — Network Monitoring and Defense

All 11 Safeguards, plain meaning, verification focus, and example evidence.



Visibility becomes defense only when alerts are tuned, investigated, and connected to response

Figure 8. Monitoring-to-response workflow

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for network monitoring and defense.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
13.1	Centralize Security Event Alerting	Put a repeatable, owned process or technical control in place to centralize Security Event Alerting, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning
13.2	Deploy a Host-Based Intrusion Detection Solution	Put a repeatable, owned process or technical control in place to deploy a Host-Based Intrusion Detection Solution, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning
13.3	Deploy a Network Intrusion Detection Solution	Put a repeatable, owned process or technical control in place to deploy a Network Intrusion Detection Solution, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning
13.4	Perform Traffic Filtering Between Network Segments	Put a repeatable, owned process or technical control in place to perform Traffic Filtering Between Network Segments, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning
13.5	Manage Access Control for Remote Assets	Put a repeatable, owned process or technical control in place to manage Access Control for Remote Assets, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning
13.6	Collect Network Traffic Flow Logs	Put a repeatable, owned process or technical control in place to collect Network Traffic Flow Logs, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning
13.7	Deploy a Host-Based Intrusion Prevention Solution	Put a repeatable, owned process or technical control in place to deploy a Host-Based Intrusion Prevention Solution, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning

ID	Safeguard	Plain meaning	Verification focus	Example evidence
13.8	Deploy a Network Intrusion Prevention Solution	Put a repeatable, owned process or technical control in place to deploy a Network Intrusion Prevention Solution, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning
13.9	Deploy Port-Level Access Control	Put a repeatable, owned process or technical control in place to deploy Port-Level Access Control, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning
13.10	Perform Application Layer Filtering	Put a repeatable, owned process or technical control in place to perform Application Layer Filtering, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning
13.11	Tune Security Event Alerting Thresholds	Put a repeatable, owned process or technical control in place to tune Security Event Alerting Thresholds, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	SIEM coverage, host/network detection, segmentation, remote controls, flow logs, prevention systems and alert tuning

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

19. Control 14 — Security Awareness and Skills Training

All 9 Safeguards, plain meaning, verification focus, and example evidence.

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for security awareness and skills training.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
14.1	Establish and Maintain a Security Awareness Program	Put a repeatable, owned process or technical control in place to establish and Maintain a Security Awareness Program, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	program, workforce population, role curriculum, completion, simulations, evaluation, exceptions and follow-up
14.2	Train Workforce Members to Recognize Social Engineering Attacks	Put a repeatable, owned process or technical control in place to train Workforce Members to Recognize Social Engineering Attacks, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	program, workforce population, role curriculum, completion, simulations, evaluation, exceptions and follow-up
14.3	Train Workforce Members on Authentication Best Practices	Put a repeatable, owned process or technical control in place to train Workforce Members on Authentication Best Practices, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	program, workforce population, role curriculum, completion, simulations, evaluation, exceptions and follow-up
14.4	Train Workforce on Data Handling Best Practices	Put a repeatable, owned process or technical control in place to train Workforce on Data Handling Best Practices, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	program, workforce population, role curriculum, completion, simulations, evaluation, exceptions and follow-up
14.5	Train Workforce Members on Causes of Unintentional Data Exposure	Put a repeatable, owned process or technical control in place to train Workforce Members on Causes of Unintentional Data Exposure, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	program, workforce population, role curriculum, completion, simulations, evaluation, exceptions and follow-up
14.6	Train Workforce Members on Recognizing and Reporting Security Incidents	Put a repeatable, owned process or technical control in place to train Workforce Members on Recognizing and Reporting Security Incidents, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	program, workforce population, role curriculum, completion, simulations, evaluation, exceptions and follow-up
14.7	Train Workforce to Identify and Report Missing Security Updates	Put a repeatable, owned process or technical control in place to train Workforce to Identify and Report Missing Security Updates, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	program, workforce population, role curriculum, completion, simulations, evaluation, exceptions and follow-up
14.8	Train Workforce on Risks of Insecure Networks	Put a repeatable, owned process or technical control in place to train Workforce on Risks of Insecure Networks, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	program, workforce population, role curriculum, completion, simulations, evaluation, exceptions and follow-up
14.9	Conduct Role-Specific Security Awareness and Skills Training	Put a repeatable, owned process or technical control in place to conduct Role-Specific Security Awareness and Skills Training, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	program, workforce population, role curriculum, completion, simulations, evaluation, exceptions and follow-up

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

20. Control 15 — Service Provider Management

All 7 Safeguards, plain meaning, verification focus, and example evidence.

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for service provider management.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
15.1	Establish and Maintain an Inventory of Service Providers	Put a repeatable, owned process or technical control in place to establish and Maintain an Inventory of Service Providers, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	provider inventory, classifications, policy, contracts, assessments, monitoring, incidents and decommission evidence
15.2	Establish and Maintain a Service Provider Management Policy	Put a repeatable, owned process or technical control in place to establish and Maintain a Service Provider Management Policy, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	provider inventory, classifications, policy, contracts, assessments, monitoring, incidents and decommission evidence
15.3	Classify Service Providers	Put a repeatable, owned process or technical control in place to classify Service Providers, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	provider inventory, classifications, policy, contracts, assessments, monitoring, incidents and decommission evidence
15.4	Ensure Service Provider Contracts Include Security Requirements	Put a repeatable, owned process or technical control in place to ensure Service Provider Contracts Include Security Requirements, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	provider inventory, classifications, policy, contracts, assessments, monitoring, incidents and decommission evidence
15.5	Assess Service Providers	Put a repeatable, owned process or technical control in place to assess Service Providers, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	provider inventory, classifications, policy, contracts, assessments, monitoring, incidents and decommission evidence
15.6	Monitor Service Providers	Put a repeatable, owned process or technical control in place to monitor Service Providers, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	provider inventory, classifications, policy, contracts, assessments, monitoring, incidents and decommission evidence
15.7	Securely Decommission Service Providers	Put a repeatable, owned process or technical control in place to securely Decommission Service Providers, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	provider inventory, classifications, policy, contracts, assessments, monitoring, incidents and decommission evidence

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

21. Control 16 — Application Software Security

All 14 Safeguards, plain meaning, verification focus, and example evidence.

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for application software security.

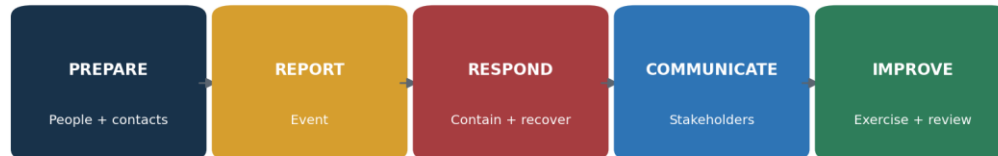
ID	Safeguard	Plain meaning	Verification focus	Example evidence
16.1	Establish and Maintain a Secure Application Development Process	Put a repeatable, owned process or technical control in place to establish and Maintain a Secure Application Development Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.2	Establish and Maintain a Process to Accept and Address Software Vulnerabilities	Put a repeatable, owned process or technical control in place to establish and Maintain a Process to Accept and Address Software Vulnerabilities, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.3	Perform Root Cause Analysis on Security Vulnerabilities	Put a repeatable, owned process or technical control in place to perform Root Cause Analysis on Security Vulnerabilities, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.4	Establish and Manage an Inventory of Third-Party Software Components	Put a repeatable, owned process or technical control in place to establish and Manage an Inventory of Third-Party Software Components, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.5	Use Up-to-Date and Trusted Third-Party Software Components	Put a repeatable, owned process or technical control in place to use Up-to-Date and Trusted Third-Party Software Components, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.6	Establish a Severity Rating System and Process for Application Vulnerabilities	Put a repeatable, owned process or technical control in place to establish a Severity Rating System and Process for Application Vulnerabilities, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.7	Use Standard Hardening Templates for Application Infrastructure	Put a repeatable, owned process or technical control in place to use Standard Hardening Templates for Application Infrastructure, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.8	Separate Production and Non-Production Systems	Put a repeatable, owned process or technical control in place to separate Production and Non-Production Systems, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.9	Train Developers in Application Security and Secure Coding	Put a repeatable, owned process or technical control in place to train Developers in Application Security and Secure Coding, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.10	Apply Secure Design Principles in Application Architectures	Put a repeatable, owned process or technical control in place to apply Secure Design Principles in Application Architectures, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.11	Use Vetted Modules or Services for Application Security Components	Put a repeatable, owned process or technical control in place to use Vetted Modules or Services for Application Security Components, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.12	Implement Code-Level Security Checks	Put a repeatable, owned process or technical control in place to implement Code-Level Security Checks, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models
16.13	Conduct Application Penetration Testing	Put a repeatable, owned process or technical control in place to conduct Application Penetration Testing, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models

ID	Safeguard	Plain meaning	Verification focus	Example evidence
16.14	Conduct Threat Modeling	Put a repeatable, owned process or technical control in place to conduct Threat Modeling, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	secure SDLC, disclosure process, root cause, component inventory, severity, hardening, training, testing and threat models

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

22. Control 17 — Incident Response Management

All 9 Safeguards, plain meaning, verification focus, and example evidence.



Incident readiness depends on practiced roles, thresholds, communication, evidence, and learning

Figure 9. Incident-response readiness

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for incident response management.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
17.1	Designate Personnel to Manage Incident Handling	Put a repeatable, owned process or technical control in place to designate Personnel to Manage Incident Handling, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	incident leaders, contacts, reporting, plan, roles, communications, exercises, reviews and thresholds
17.2	Maintain Contact Information for Reporting Security Incidents	Put a repeatable, owned process or technical control in place to maintain Contact Information for Reporting Security Incidents, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	incident leaders, contacts, reporting, plan, roles, communications, exercises, reviews and thresholds
17.3	Maintain an Enterprise Process for Reporting Incidents	Put a repeatable, owned process or technical control in place to maintain an Enterprise Process for Reporting Incidents, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	incident leaders, contacts, reporting, plan, roles, communications, exercises, reviews and thresholds
17.4	Establish and Maintain an Incident Response Process	Put a repeatable, owned process or technical control in place to establish and Maintain an Incident Response Process, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	incident leaders, contacts, reporting, plan, roles, communications, exercises, reviews and thresholds
17.5	Assign Key Roles and Responsibilities	Put a repeatable, owned process or technical control in place to assign Key Roles and Responsibilities, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	incident leaders, contacts, reporting, plan, roles, communications, exercises, reviews and thresholds
17.6	Define Mechanisms for Communicating During Incident Response	Put a repeatable, owned process or technical control in place to define Mechanisms for Communicating During Incident Response, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	incident leaders, contacts, reporting, plan, roles, communications, exercises, reviews and thresholds
17.7	Conduct Routine Incident Response Exercises	Put a repeatable, owned process or technical control in place to conduct Routine Incident Response Exercises, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	incident leaders, contacts, reporting, plan, roles, communications, exercises, reviews and thresholds
17.8	Conduct Post-Incident Reviews	Put a repeatable, owned process or technical control in place to conduct Post-Incident Reviews, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	incident leaders, contacts, reporting, plan, roles, communications, exercises, reviews and thresholds

ID	Safeguard	Plain meaning	Verification focus	Example evidence
17.9	Establish and Maintain Security Incident Thresholds	Put a repeatable, owned process or technical control in place to establish and Maintain Security Incident Thresholds, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	incident leaders, contacts, reporting, plan, roles, communications, exercises, reviews and thresholds

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

23. Control 18 — Penetration Testing

All 5 Safeguards, plain meaning, verification focus, and example evidence.

Control purpose: Strengthen the enterprise by implementing and measuring safeguards for penetration testing.

ID	Safeguard	Plain meaning	Verification focus	Example evidence
18.1	Establish and Maintain a Penetration Testing Program	Put a repeatable, owned process or technical control in place to establish and Maintain a Penetration Testing Program, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	approved rules of engagement, scope, qualified testers, reports, remediation, retest and validation evidence
18.2	Perform Periodic External Penetration Tests	Put a repeatable, owned process or technical control in place to perform Periodic External Penetration Tests, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	approved rules of engagement, scope, qualified testers, reports, remediation, retest and validation evidence
18.3	Remediate Penetration Test Findings	Put a repeatable, owned process or technical control in place to remediate Penetration Test Findings, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	approved rules of engagement, scope, qualified testers, reports, remediation, retest and validation evidence
18.4	Validate Security Measures	Put a repeatable, owned process or technical control in place to validate Security Measures, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	approved rules of engagement, scope, qualified testers, reports, remediation, retest and validation evidence
18.5	Perform Periodic Internal Penetration Tests	Put a repeatable, owned process or technical control in place to perform Periodic Internal Penetration Tests, then verify coverage and exceptions.	Confirm defined scope, population, ownership, implementation, frequency, coverage, exceptions, correction, and retest.	approved rules of engagement, scope, qualified testers, reports, remediation, retest and validation evidence

Use the official CIS Controls v8.1 guide and Controls Assessment Specification for exact Safeguard language, asset class, security function, Implementation Group, dependencies, inputs, operations, measures, metrics, and procedural review.

24. Open-Source Tools

Official links, safe quick starts, evidence, and limitations.

Tool	Purpose	Possible Controls
CIS Controls Navigator	Select IGs and explore official mappings	All
CIS Controls Assessment Specification	Official measurement guidance	All
CIS-CAT Lite	Selected CIS Benchmark assessment	4
CISO Assistant	Controls, risks, evidence, and findings	All
Wazuh	Endpoint monitoring, SIEM, FIM, and alerts	1, 4, 8, 10, 13, 17
osquery	Asset, software, account, and configuration queries	1, 2, 4, 5, 8
OpenSCAP	Linux secure-configuration assessment	4, 7
Lynis	Linux security auditing	4, 7
Nmap	Authorized asset and service discovery	1, 12
Greenbone Community Edition	Vulnerability assessment	7
Trivy	Repositories, images, dependencies, secrets, and IaC	2, 4, 7, 16
OWASP ZAP	Authorized web security testing	16, 18
Suricata	Network intrusion detection and traffic visibility	8, 13, 17
Keycloak	Identity, roles, MFA, sessions, and events	5, 6, 8
DefectDojo	Finding intake, deduplication, remediation, and retest	7, 16, 18
Velociraptor	Endpoint visibility and incident response	1, 8, 13, 17

Critical limitation: A tool can support one or more Safeguards, but it cannot choose the organization's IG, define risk tolerance, guarantee complete coverage, replace procedure and human review, authorize penetration testing, or prove another framework's compliance by itself.

24.1 CIS Controls Navigator

Purpose: Select IGs and explore official mappings. Official project: [CIS Controls Navigator](#)

Safe quick start: Choose v8.1, select an Implementation Group and mapping, review Safeguards, then export the authorized selection.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.2 CIS Controls Assessment Specification

Purpose: Official measurement guidance. Official project: [CIS Controls Assessment Specification](#)

Safe quick start: Open a Safeguard, identify inputs and assumptions, follow operations, calculate measures, and document procedure review.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.3 CIS-CAT Lite

Purpose: Selected CIS Benchmark assessment. Official project: [CIS-CAT Lite](#)

Safe quick start: Run only on authorized systems, choose an available benchmark and profile, preserve the report, validate findings, correct, and reassess.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.4 CISO Assistant

Purpose: Controls, risks, evidence, and findings. Official project: [CISO Assistant](#)

Safe quick start: Create a scoped project, load an applicable framework, assign owners, attach evidence, track findings, and review permissions.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.5 Wazuh

Purpose: Endpoint monitoring, SIEM, FIM, and alerts. Official project: [Wazuh](#)

Safe quick start: Enroll a lab endpoint, trigger a safe event, confirm collection and alerting, investigate, and retain coverage and response evidence.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.6 osquery

Purpose: Asset, software, account, and configuration queries. Official project: [osquery](#)

Safe quick start: Run read-only queries in a lab, schedule approved queries, compare results to inventories, and document platform and coverage limits.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.7 OpenSCAP

Purpose: Linux secure-configuration assessment. Official project: [OpenSCAP](#)

Safe quick start: Choose an appropriate profile, scan a lab system, validate results, document exceptions, remediate, and rescan.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.8 Lynis

Purpose: Linux security auditing. Official project: [Lynis](#)

Safe quick start: Audit a lab host, review findings against scope and standards, assign actions, correct selected items, and rerun.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.9 Nmap

Purpose: Authorized asset and service discovery. Official project: [Nmap](#)

Safe quick start: Use a limited scan on written-authorized ranges, compare to inventory, investigate unknown services, and retain scope and command evidence.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.10 Greenbone Community Edition

Purpose: Vulnerability assessment. Official project: [Greenbone Community Edition](#)

Safe quick start: Update feeds, use authorized targets and credentials, validate asset coverage, review findings, remediate, and rescan.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.11 Trivy

Purpose: Repositories, images, dependencies, secrets, and IaC. Official project: [Trivy](#)

Safe quick start: Scan a test repository or image, validate findings, document justified exceptions, fix, and rescan in the pipeline.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.12 OWASP ZAP

Purpose: Authorized web security testing. Official project: [OWASP ZAP](#)

Safe quick start: Proxy a training application, crawl passively, use active scanning only with approval, validate findings, correct, and retest.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.13 Suricata

Purpose: Network intrusion detection and traffic visibility. Official project: [Suricata](#)

Safe quick start: Use a lab sensor, confirm interface and rules, generate approved test traffic, validate alerts, tune carefully, and preserve change history.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.14 Keycloak

Purpose: Identity, roles, MFA, sessions, and events. Official project: [Keycloak](#)

Safe quick start: Create a lab realm, roles and MFA, test joiner-mover-leaver cases, review events, and document configuration and results.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.15 DefectDojo

Purpose: Finding intake, deduplication, remediation, and retest. Official project: [DefectDojo](#)

Safe quick start: Import safe results, validate deduplication, assign owners and dates, attach proof, and close only after verified retest.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

24.16 Velociraptor

Purpose: Endpoint visibility and incident response. Official project: [Velociraptor](#)

Safe quick start: Deploy only in an isolated authorized lab, collect a narrow artifact, document scope and access, investigate results, and remove lab data safely.

Evidence: approved scope, version, configuration, coverage, source data, results, human review, exception, remediation, and retest. Protect administrative access and collected data.

25. Manager's CIS Controls Playbook

Questions, dashboard, ownership, and decisions managers must control.

1. Is the chosen IG still appropriate for sensitive data, critical services, threat exposure, obligations, scale, and skills?
2. Are the core populations complete, current, owned, and reconciled to independent discovery?
3. Which IG1 Safeguards have incomplete coverage, overdue review, unreliable input data, or repeat exceptions?
4. Are administrative access, externally exposed systems, unsupported software, critical vulnerabilities, and recovery failures escalated?
5. Do alerts result in investigation and response, or only dashboard volume?
6. Are service-provider responsibilities, evidence, incident obligations, subcontractors, and exit plans understood?
7. Are penetration tests and exercises safely authorized, appropriately scoped, independently performed where needed, and followed through retest?
8. What funding, staff, engineering time, or business decision is blocking correction?

Area	Manager question	Status
IG and scope	Are prioritization, additions, exclusions, and obligations documented?	Green / Yellow / Red
Inventories	Are assets, software, data, accounts, suppliers, applications, and logs complete?	Green / Yellow / Red
Protection	Are configuration, access, patching, email, malware, and data controls operating?	Green / Yellow / Red
Detection	Are log and network coverage complete and alerts reviewed?	Green / Yellow / Red
Recovery	Are protected backups and restores tested against business needs?	Green / Yellow / Red
Response	Are roles, contacts, thresholds, exercises, and reviews current?	Green / Yellow / Red
Measurement	Are inputs reliable and exception populations corrected?	Green / Yellow / Red
Assurance	Are testing, limitations, findings, and retests supportable?	Green / Yellow / Red

26. Junior Analyst Career Guide

A practical route into controls, vulnerability, assurance, GRC, and security operations work.



A strong portfolio uses synthetic data, authorized tools, complete populations, and honest conclusions

Figure 10. Junior CIS Controls analyst pathway

Junior Security Controls Analyst
GRC Analyst
Vulnerability Management Analyst
Security Assurance Analyst
Security Operations Analyst
IT Compliance Analyst
Third-Party Risk Analyst
Cybersecurity Program Analyst

26.1 Typical junior work

- Maintain inventories for assets, software, data, accounts, network systems, suppliers, applications, findings, and evidence.
- Gather evidence without changing source records and validate population completeness.
- Map Safeguards to owners, systems, procedures, configuration, evidence, metrics, exceptions, and actions.
- Run authorized discovery, configuration, vulnerability, logging, or application-security tools under approved procedures.
- Calculate coverage and exception metrics using the official assessment structure.
- Track unsupported software, unauthorized assets, access issues, vulnerabilities, failed backups, alert gaps, and supplier findings through retest.
- Write clear conclusions without claiming authority or certainty beyond the evidence.

Skill	Portfolio proof
-------	-----------------

Skill	Portfolio proof
Framework	Explain the 18 Controls, IGs, asset classes, and functions
Inventory	Reconcile two independent sources and explain differences
Measurement	Show inputs, operations, measures, metric, exception list, and conclusion
Technical literacy	Interpret configuration, identity, scan, log, recovery, and application evidence
Remediation	Trace finding to owner, due date, correction, and verified retest
Communication	Write a one-page manager summary and a detailed workpaper
Ethics	Use synthetic data, authorization, scope limits, and honest claims

27. Fictional Laboratory and Portfolio

A safe practice environment using synthetic data and authorized lab systems.

Lab rule: Use fictional organizations, synthetic data, isolated systems, and written authorization. Never attack public targets, use real credentials, or publish sensitive tool output.

1. Create a fictional 50-person company with laptops, servers, cloud services, a web application, remote staff, and five suppliers.
2. Select IG1 and document three risk-based additions from IG2 or IG3.
3. Build enterprise-asset, software, data, account, authentication-system, network, supplier, application, and log-source inventories.
4. Use Nmap and osquery in an isolated lab to reconcile asset and software inventories.
5. Use OpenSCAP or Lynis on a lab host; document configuration findings, exceptions, corrections, and reassessment.
6. Use Greenbone on approved lab targets; validate coverage, findings, remediation, and rescan.
7. Use Wazuh or Suricata to generate and investigate a safe test alert.
8. Use Trivy or ZAP on a training repository or application and record correction and retest.
9. Write a backup-restore test and incident tabletop record.
10. Create five CIS Assessment Specification workpapers with inputs, operations, measures, metrics, exception lists, and conclusions.
11. Publish only sanitized artifacts and state clearly that the project is fictional and not a formal CIS assessment.

Artifact	What it proves
IG selection memo	Prioritization and risk reasoning
Inventory reconciliation	Population completeness and analytical skill
Safeguard workpaper	Official measurement structure and evidence
Configuration reassessment	Technical finding, correction, and retest
Vulnerability report	Coverage, prioritization, exception, and remediation
Detection case	Alert validation, investigation, and response
Restore test	Availability and recovery evidence
Manager dashboard	Clear risk and action communication

28. Thirty-Day Learning Plan

A focused schedule for useful junior-level capability.

Days	Focus	Deliverable
1–4	Framework, 18 Controls, 153 Safeguards, IGs, asset classes, functions	Framework concept map and IG memo
5–8	Assets, software, data, accounts, access	Four reconciled inventories
9–12	Configuration, vulnerability, email, malware	Lab configuration and vulnerability workpaper
13–16	Logs, monitoring, network defense	Log-source map and safe alert case
17–19	Recovery and incident response	Restore test and tabletop record
20–22	Suppliers and application security	Provider assessment and secure-development checklist
23–25	Assessment Specification	Five complete Safeguard measurements
26–28	Authorized tool labs and remediation	Two correction and retest memos
29–30	Portfolio and interviews	Sanitized portfolio and five STAR stories

29. Interview Preparation

Clear answers, practical scenarios, and questions for the employer.

29.1 What are the CIS Controls?

A prioritized set of defensive best practices organized into 18 Controls and 153 focused Safeguards.

29.2 What is IG1?

The 56-Safeguard essential cyber hygiene starting point that CIS recommends every enterprise begin with.

29.3 Does IG1 fit every requirement?

It is a prioritization baseline. Material risk, contracts, laws, customers, or critical services may require additional Safeguards.

29.4 How do you measure a Safeguard?

Use official criteria, dependencies, assumptions, complete inputs, defined operations, measures, metrics, procedure review, exceptions, and retesting.

29.5 Why are inventories important?

They define the populations that configuration, vulnerability, logging, recovery, and response controls must cover.

29.6 Vulnerability scan versus penetration test?

A scan mainly identifies known weaknesses; penetration testing uses skilled human analysis and controlled exploitation to evaluate impact and resilience.

29.7 Does a framework mapping prove compliance?

No. It identifies relationships, but the organization must test the exact applicable requirement and evidence.

29.8 What can a junior analyst conclude?

Only what the defined scope and reliable evidence support, with sampling and limitations clearly disclosed.

29.9 Questions to ask the employer

Which Implementation Group and additions are in scope?

How are inventory populations created and reconciled?

Which Safeguards have the most incomplete coverage?

How are measurement data and exceptions reviewed?

Which open-source and commercial tools are approved?

How are findings prioritized, funded, and retested?

How will senior staff review junior work?

30. Templates, Glossary, Index, and References

Reusable work structures, important terms, and authoritative starting points.

30.1 Safeguard measurement workpaper

Field	Entry
Safeguard and IG	
Scope and asset class	
Owner and systems	
Dependencies and assumptions	
Inputs and validation	
Operations performed	
Measures	
Metric and interpretation	
Exceptions and limitation	
Action, owner, date, and retest	

30.2 Finding and retest record

Field	Entry
Criteria	
Condition and evidence	
Affected population	
Risk and impact	
Cause	
Interim protection	
Correction and owner	
Due date	
Retest procedure	
Final result	

30.3 Glossary

Term	Meaning
Asset class	Category affected by a Safeguard, such as devices, software, data, network, users, or documentation.
CIS Benchmark	Secure-configuration recommendations for a specific technology.
CIS Control	One of 18 broad defensive areas.
CIS Safeguard	A focused, implementable action within a Control.
Coverage	Share of the applicable population on which the Safeguard is properly implemented.
IG1	56 essential cyber hygiene Safeguards.
IG2	IG1 plus 74 additional Safeguards.
IG3	IG1 and IG2 plus 23 additional Safeguards; all 153.
Measure	A count, list, date, setting, or result produced by assessment operations.
Metric	Calculation or interpretation built from measures.
Population	Complete set of applicable records, assets, people, systems, or events.
Procedure review	Manual evaluation of whether a required process exists and contains needed elements.
Security function	Govern, Identify, Protect, Detect, Respond, or Recover mapping.

30.4 Subject index

Subject	Chapter
Accounts	9–10
Application security	21
Asset inventory	6
Audit logs	13
Data protection	8
Evidence and measurement	4
Implementation Groups	2
Incident response	22
Junior analyst	26–29
Malware	15
Manager	25
Network	17–18
Open-source tools	24
Penetration testing	23
Recovery	16
Service providers	20
Software inventory	7
Training	19
Vulnerability management	12

30.5 Official references

[CIS Controls v8.1](#)

[18 CIS Controls list](#)

[Implementation Groups](#)

[Controls Assessment Specification](#)

[Assessment Specification documentation](#)

[CIS Controls Navigator](#)

[CIS Controls mappings and compliance](#)

Final reminder: Frameworks, mappings, tools, products, threats, laws, contracts, and organizational risks change. Confirm official current resources and applicable obligations before a real implementation or assessment.